

Detection Explorer Second Pass

What shipped since the last review, what's still open, and a first proper audit of the normalization layer — where the taxonomy claims on the methodology page and the values in the live facets disagree.

REVIEWED 31 AUG 2026 BACKEND COMMIT 2386DE90 CORPUS 15,584 RULES · 13 REPOS
FINDINGS R01–R25

Where it stands

Most of the last list actually shipped, and several items shipped better than specified — the permalink guarantee is real and verifiable, the metadata-completeness rework is a genuinely good piece of measurement design, and the search relevance fix took the site from embarrassing to good on broad queries. Query performance went from 1.3–1.5 s to under 110 ms.

Two things are worth acting on this week. First, **a single missing rewrite is breaking three visible features at once** — `/api/*` isn't proxied on the apex domain, so your OG image 404s, RSS autodiscovery 404s, and the digest hands subscribers a `railway.app` URL (R01). Second, **the normalization layer doesn't yet match what the methodology page promises**, and that's now a credibility exposure rather than just a data-quality one, because the claim is written down (R08–R14).

A Verified as shipped

Each of these I re-tested rather than took on trust.

✓ Admin routes gone

✓ Permalink guarantee

Sync, ingest, MITRE refresh and scheduler trigger no longer appear in the public OpenAPI spec. Remaining POSTs are read-shaped (search, export, compare).	Legacy id, vendor id and canonical id all resolve to the same rule, with redirects to the canonical UUID. Works exactly as the methodology page states.
✓ Metadata completeness Renamed, format-aware denominators, caveat above the number, no vendor ranking. Per-source means went from a 34–70 spread to 54–74.	✓ Search relevance All six broad queries I tried now return an on-topic rule at rank 1. "ransomware" leads with "Common Ransomware Notes" instead of an NFS burst rule.
✓ Query performance Facets 1,503 ms → 95 ms. List 1,278 ms → 102 ms. Twelve calls all under 110 ms.	✓ Sitemap & naming 17,300 URLs with lastmod, served as real XML and cached an hour. Site consistently named Detection Explorer.
✓ Methodology page Promoted, in the nav, with per-source licenses, permalink guarantee and taxonomy sections. Strongest page on the site.	✓ Digest archive Week permalinks with prev/next and an explicit "this URL always shows this week". Cross-vendor panel now reports coverage gaps honestly.
✓ Mobile nav, fonts, licenses Hamburger below 768px, self-hosted fonts, license badge on rule pages, author falls back to the repo, analytics installed.	

B Infrastructure — one root cause, three broken features

R01

/api/* is not proxied on the apex domain CRITICAL

Every `/api/...` path on `detectionexplorer.io` returns the 2,308-byte SPA shell with `x-vercel-cache: HIT`. The backend is still only reachable at the Railway hostname, which the frontend calls cross-origin. Three user-visible consequences:

- **Your OG image is dead.** The shell declares `og:image = https://detectionexplorer.io/api/og/site.png`. I loaded it as an image: error. It serves HTML. The generator works perfectly on the Railway host (`image/png`, `s-maxage=86400`) — it's just unreachable at

the URL you publish. Every unfurl on LinkedIn, Slack and X currently renders with no image.

- **RSS autodiscovery is dead.** `<link rel="alternate" href="/api/digest/feed.xml">` returns HTML too, so no reader will find your feeds from the page.

- **Subscribers get pinned to Railway.** The digest's Subscribe block prints `https://threat-detection-explorer-production.up.railway.app/api/digest/feed.xml` for people to paste into their reader. The day you move off Railway, every subscriber breaks silently.

FIX One Vercel rewrite: `/api/:path*` → the Railway origin, and switch the frontend's base URL to same-origin. That single change fixes the OG image, RSS autodiscovery, the printed feed URLs, the apex `/api/docs`, and removes the CORS preflight — and it finally puts a CDN in front of the API (see R02).

R02

Cache headers are set but nothing is caching **HIGH**

API responses now carry `public, s-maxage=900, stale-while-revalidate=86400` — correct, and exactly what was asked for. But there's no shared cache to honour it: no `age`, no `cf-cache-status`, no CDN in front of the Railway container. Every request still reaches origin. The speed you gained is real but it's all origin CPU on one box, which is precisely the thing that falls over when a post lands.

FIX Comes free with R01. Once `/api` is behind Vercel (or Cloudflare), those headers start doing work. Add a purge at the end of the nightly ingest so the 15-minute TTL doesn't hold stale counts.

R03

The bot prerender probably isn't reaching bots **VERIFY**

The prerender endpoints are excellent — real `h1`, description, canonical pointing at the resolved id, ATT&CK link, the full detection logic in a `<pre>`. But at the apex, a rule URL returns the plain shell with `x-vercel-cache: HIT`, `age: 75310` (21 hours) and **no Vary: User-Agent**. A response that varies by user agent without declaring it gets cached as a single variant and served to everyone — so even if the middleware is wired, the CDN is very likely serving the shell to Googlebot from cache.

FIX Add `Vary: User-Agent` on the HTML route (or key the cache on a bot flag), then confirm with Search Console's live URL inspection on three detail pages. This matters more now than it did: your sitemap declares 15,585 detection URLs. If they render as identical empty shells, you've submitted 15,585 duplicate thin pages, which is worse for the domain than submitting none.

c Normalization — the taxonomy doesn't match the claim

The methodology page states: "Vendor logsources resolve to one platform / data-source / event-type vocabulary through per-vendor mapping files." That's the right promise. The live facet values don't keep it yet, and now that it's written down, the gap is a credibility problem rather than a backlog item.

R04

The data-source vocabulary has synonyms, not canonical names **CRITICAL**

151 values, and several vendor families appear under two or more spellings. A user filtering one of them silently misses the rules filed under the other:

FAMILY	COMPETING VALUES IN THE LIVE FACET
Microsoft 365	<code>m365_audit</code> (341) · <code>m365_exchange_audit</code> (13) · <code>microsoft365_exchange_audit</code> (2) · <code>microsoft365_sharepoint_audit</code> (2) · <code>m365_purview_audit</code> (2)
Defender	<code>m365_defender</code> (273) · <code>defender_endpoint</code> (139) · <code>defender_cloud</code> (36) · <code>windows_defender_event_log</code> (17) · <code>microsoft_defender_xdr</code> (12)
Azure	<code>azure_activity</code> (295) · <code>azure_monitor_activity</code> (95) · <code>azure_audit</code> (30)
Windows logs	<code>windows_security_event_log</code> (4,442) · <code>windows_event_logs</code> (83)
Carbon Black	<code>carbon_black</code> (663) · <code>carbon_black_audit</code> (10) · <code>carbon_black_alert</code> (2)

Two naming conventions coexist (`m365_` vs `microsoft365_`), and generic buckets sit alongside product feeds at the same level: `application_logs` (369), `webserver_logs` (181), `proxy_logs` (165), `network_traffic_logs` (100), `antivirus_logs` (19), `database_logs` (2).

FIX An explicit alias table mapping every accepted spelling to one canonical id, plus a CI check that fails the build when a new facet value is within an edit-distance or prefix-synonym of an existing one. Publish the canonical list on the methodology page — that turns the claim into something a reader can check.

R05

platform conflates three different axes CRITICAL

56 values, mixing operating systems (`windows` , `linux` , `macos`), cloud providers (`aws` , `azure` , `gcp` , `oci` , `kubernetes`), SaaS applications (`notion` , `asana` , `zendesk` , `zoom` , `box` , `dropbox` , `docusign`) and security products (`crowdstrike` , `sentinelone` , `carbon_black` , `wiz` , `netskope` , `zscaler` , `orca` , `thinkst_canary` , `axonius` , `upwind`). `crowdstrike` is simultaneously a platform value and a data-source prefix.

The cause is visible in the per-source counts: Panther contributes 50 distinct platforms and PyPanther 47, out of 56 total. Panther's log-type vocabulary is being written straight into the platform axis, while a Sigma rule for the same CrowdStrike telemetry is correctly tagged `windows` . So the facet answers a different question depending on which repo the rule came from — which is the one thing a normalized schema must not do.

FIX Split into three fields with one meaning each: `platform` (OS/runtime only — `windows`, `linux`, `macos`, `container`, `cross_platform`, `unknown`), `surface` (endpoint, identity, cloud, `saas`, `network`, `email`), and `product` (the vendor or application name). Everything currently in the tail moves to `product` , and `platform` drops to about eight values that mean the same thing everywhere.

R06

event_type mixes event category, vendor event names and rule modality HIGH

Three distinct problems inside 52 values. **Parent and child coexist without a hierarchy:** `registry_event` (407) sits beside

registry_set (240), registry_delete (10), registry_add (3), registry_rename (1); file_event (966) beside file_delete (24), file_change (3), file_delete_detected (11), file_executable_detected (8), file_block_executable (2), file_block_shredding (1) — so filtering the parent misses the children and vice versa. **Vendor names leak through un-normalized:** file_delete_detected and file_block_shredding are Elastic Defend strings; ps_script / ps_module / ps_classic and sysmon_status / sysmon_error are Sigma logsource names. **And four values aren't event types at all:** hunting_query (140 — exactly the Elastic Hunting rule count), ml_detection (106 — exactly the Elastic ML count), platform_alert (219) and alert_correlation (150) describe how the rule works, not what it observes.

FIX Two-level event_category → event_subtype so parents roll up children, and a separate rule_modality field (rule / hunting_query / ml_job / correlation / building_block) for the four strays.

R07

Language has the same modality leak, plus a parse fallback MEDIUM

Of 14 values, ml (106), threat_match (6) and panther_correlation (3) are rule types, not query languages. And panther (1) — a single rule — is a language-detection fallback that made it into production as a facet value.

FIX Move modality to rule_modality alongside R06, and make the language resolver fail loudly: a rule the parser can't classify should be logged and counted, not given the source name as its language.

R08

Severity is fabricated for roughly 1,500 rules CRITICAL

Three sources return a single severity for every rule they have — elastic_protections 1,314/1,314 medium, elastic_hunting 140/140 medium, okta 34/34 medium. Those upstreams don't publish a severity, so the default is being presented to users as data. Severity is a primary filter, which means severity:medium currently returns a bucket padded with "we didn't know."

Splunk has a related but different problem: 2,156 rules resolve to low 1,063, medium 1,078, high 15, critical 0. No Splunk engineer will

believe that 0.7% of Splunk Security Content is high severity — the risk-score bucketing is mis-calibrated.

FIX Allow `severity: null` and add `severity_origin: upstream | derived | none`. Render "not specified" in the UI, exclude nulls from severity facet counts rather than folding them into medium, and publish the Splunk `risk_score` → severity thresholds on the methodology page so the mapping is arguable rather than mysterious.

R09

status is a constant for seven of thirteen sources HIGH

`elastic`, `elastic_protections`, `elastic_hunting`, `sublime`, `okta` and `google_secops` return "stable" for 100% of their rules; `auth0` returns "experimental" for 100%. Sentinel returns "unknown" for 1,827 of 2,369 — that one value alone is 12% of the whole corpus. A facet that is constant per source is not a facet, it's a source label with extra steps. Elastic in particular does publish a `maturity` field that isn't being read.

FIX Map Elastic `maturity` properly. For sources with no status concept, render "not applicable" rather than defaulting to stable, and hide the facet when the active source filter makes it meaningless.

R10

Sublime still has zero ATT&CK mapping — 1,209 rules, and the data exists upstream HIGH VALUE

Every one of Sublime's 1,209 rules has no technique and no tactic, which is 7.8% of the corpus unmapped and concentrated in exactly the initial-access/phishing space where your coverage story is thinnest. This is also what still drags Sublime's completeness score (mean 57 vs Elastic's 69) after the rebalance.

But you're already ingesting `use_cases: Credential Phishing` from those rules, which means the upstream classification fields are being read and then dropped. Sublime's `attack_types` vocabulary is small and maps cleanly: Credential Phishing → T1566.002, Malware/Ransomware → T1204.002, BEC/Extortion → T1534, attachment-based → T1566.001, link-based → T1566.002.

FIX A ~30-line mapping table adds around 1,200 mapped rules, lifts Sublime's score for the right reason, and moves your headline technique-coverage number on real evidence. Mark them `mapping_origin: derived` so they're distinguishable from vendor-declared tags. Google

SecOps deserves the same treatment — 55 distinct techniques across 379 rules is low.

R11

Deprecated rules leak in through a title convention MEDIUM

Searching "deprecated" returns 37 hits, 18 of which carry it in the title — almost all Elastic: "Deprecated - Unusual Discovery Activity by User", "Deprecated - Microsoft Exchange Transport Agent Install Script", "Deprecated - PowerShell Script with Discovery Capabilities". Elastic retires rules by renaming them in place, not only by moving them to `_deprecated/`. Your methodology says deprecated content is excluded "everywhere the vendor marks it" — here the vendor marks it and the pipeline misses it. One of these surfaced at rank 3 for a plain "ransomware" search.

FIX Title-prefix detection into a real `deprecated` boolean, excluded from default views, from coverage math and from the digest, but still reachable by direct link with a banner. Then extend the drift check to alert when a rule's title gains a deprecation marker.

R12

Event IDs aren't namespaced by channel MEDIUM

438 values with bare `1` (26), `3` (30), `7` (40) and `10` (23) — Sysmon IDs — sitting in the same flat space as `4104`, `4688` and `5145` from the Security channel. Event ID 1 means Sysmon ProcessCreate in one rule and something entirely different in another, and `eventid:1` can't distinguish them. This is the one observable surface that's actively misleading rather than merely untidy.

FIX Namespace as `sysmon:1` / `security:4688` / `powershell:4104`, keep the bare number as a searchable alias, and show the channel in the observables table.

R13

Observables ranking is dominated by one rule family MEDIUM

On `/observables`, ranks 4, 6, 7, 10, 12, 13 and 14 are `bash` (315), `sh` (310), `zsh` (303), `dash` (232), `ksh` (225), `fish` (221), `tcsh` (218) — near-identical counts because a small number of Elastic Protections rules enumerate every shell on the system. The page is presenting list length as detection focus. It's a genuinely great page otherwise, which is why this stands out.

FIX Count distinct rule families rather than raw rule hits, or collapse enumerated sets (shells, browsers, archivers) into a single grouped row that expands. Same treatment would help the `api_actions` tail.

R14

Give `unknown` a page and a burn-down **MEDIUM**

Current unclassified counts: status 1,829 · platform 556 · data_source 280 · event_type 125 · severity 11. The methodology page already makes the right promise here — "rules the resolver cannot place show unknown rather than a guess" — which is exactly the honest choice. The next step is making it visible.

FIX A `/methodology/unclassified` page listing what didn't resolve, by source and field, with the count trending over time. It's a public honesty signal, it turns mapping work into a visible backlog, and it's the kind of thing a maintainer will happily send you a PR for.

D Front end

R15

The list endpoint ships 149 KB to render 25 rows **HIGH**

Each row averages ~10 KB and carries the complete `detection_logic` (6.3 KB on the row I measured), plus `false_positives`, `references`, `investigation` fields and all eight `extracted_*` arrays. The table renders ten columns, none of which need any of that. Roughly 85% of the payload is discarded on arrival, on the single most-requested endpoint on the site.

FIX A slim list serializer, or `?fields=` projection with the table's ten columns as the default. Expanding a row can fetch the rest. This is now the largest remaining performance item, since the queries themselves are fast.

R16

Twelve API calls per page load, five of them daily-static **MEDIUM**

`/api/mitre`, `/api/query/fields`, `/api/query/event-ids`, `/api/detections/filters` and `/api/detections/facets` are reference data that only changes after a nightly sync, and they're refetched on every navigation.

FIX One `/api/bootstrap` response cached client-side keyed on the corpus `updated_at` that `/api/health` already returns. Four fewer round trips on every page.

R17

Font preloads are being wasted **MEDIUM**

The console warns that both preloaded faces — `orbitron-var-latin.woff2` and `rajdhani-400-latin.woff2` — were "preloaded but not used within a few seconds of load." The preload isn't matching the request the CSS actually makes, usually a `crossorigin` or format mismatch, so you're paying for two extra downloads and still getting the flash you added them to prevent. Six woff2 files load per page in total, with Rajdhani shipped as four separate static weights.

FIX Match the preload to the exact request (same URL, same `crossorigin`), and ship Rajdhani as a variable font to drop three requests.

R18

Mobile has a nav now, but the table is still a table **HIGH**

At 375px only the Title column is on screen — source, severity, platform, data source, event type and completeness are all off to the right, so the metadata that makes the site useful is invisible on a phone. The bulk-select checkbox column takes ~13% of the width for an action nobody performs on mobile, and SORT and LIMIT each occupy a full row, pushing the first result past 700px. About four rules fit per screen.

FIX Card layout under 640px — title, source badge, severity chip, one metadata line — drop the checkbox column, and put sort and limit on one row. Given that most shared links get opened on phones, this is the highest-impact remaining UI item.

R19

The metric has three names **LOW**

The detections table column header still says **Hygiene**. The detail page says **Metadata completeness**. The digest says **meta**. The rename was the right call; it's just not finished.

FIX One name everywhere, including the export column header and the API field name.

R20

The score display contradicts itself **LOW**

The Sublime rule shows **57/100** directly above "scored over the 58 points this format can express", with subscores of 14/17, 11/20, 8/12 and 0/9 — which sum to 33 out of 58. Both numbers are correct and together they read as a bug. The format-aware denominator is the clever part of this design and the display undersells it.

FIX Show **33 / 58 points** as the primary figure with "57%" secondary, or just "57%". Not "/100" alongside a stated denominator of 58.

R21

"Relevance" with an empty query is a metadata-score ranking MEDIUM

The default view sorts by relevance with no query, which resolves to completeness score descending — the first five rows are all 88s and four of the five are Splunk. Since Splunk scores highest of any source on your metric, the default catalog view systematically over-represents one vendor, and the label doesn't say so.

FIX Either rename the empty-query default to "Best documented", or diversify the first page across sources. The second is better: the first screen is where a visitor forms their impression of what the corpus contains.

R22

Source cards truncate on the home page LOW

At 1280px: "Elastic Dete...", "Splunk Secur...", "Microsoft Se...", "Sublime Secu...", "Elastic Protec...", "Elastic Hunt...". Thirteen cards in a five-column grid also leaves a ragged three-card final row. The rule counts are the widest element and they're squeezing the names.

FIX Stack the count under the name, or move to a four-column grid where thirteen cards break more evenly.

R23

The address bar isn't canonicalized LOW

The redirect chain works — I verified that the legacy id, the vendor id and the canonical id all resolve to the same rule, and the prerender emits the canonical URL correctly. But the SPA leaves whichever id you arrived with in the address bar, so someone who followed an old link copies a non-canonical URL onward.

FIX `history.replaceState` to the canonical id once the rule resolves.

R24

Small accessibility gaps LOW

The basics are right — one `h1` per page, a `main` landmark, `lang` set, every button labelled, no unlabelled inputs. Missing: a skip link (relevant with eight nav items before content), and `scope` attributes on the data tables' header cells, which is what makes a wide table navigable in a screen reader.

FIX Add a visually-hidden skip link and `<th scope="col">`. Half an hour, and it's the kind of thing an enterprise reader checks.

R25

Version string is stale in two places LOW

Header and footer both read `v1.4.0`, unchanged since the last review, while `/api/health` reports commit `2386de90` and a corpus updated today. On a site whose pitch is reproducibility, a version number that doesn't move is an odd note.

FIX Wire it to the build's git describe, or drop it.

E Still on the table from last time

Not re-argued here, just noted as still open, with what changed.

EMAIL DIGEST

Still RSS and JSON only. The archive work shipped and it's good — week permalinks, prev/next, an explicit "this URL always shows this week". That makes the email version more valuable, not less: every issue now has somewhere permanent to link back to.

PUBLIC API

Still only on the Railway hostname. `/api/docs` on the apex returns the SPA shell and `robots.txt` still carries `Disallow: /api/`. R01 makes this a one-line follow-up. The spec is 67 endpoints and in good shape; it deserves a front door, a `/v1` prefix and a fair-use note.

MCP SERVER

Not shipped. Unchanged in priority. The read API is now fast enough to sit behind an agent loop without embarrassment, which it wasn't in the last review.

LEAD WITH THE
GAP

Home page still opens with the catalog. "15,584 detection rules from 13 open-source repositories" is the first sentence; "186 / 207 techniques covered" is the third stat in a row of four. The gap ranking is still the most interesting thing you have and it's still the fourth nav item.

NEW: CORPUS-
HEALTH
REPORTING

You can now measure things nobody else can. From a 600-rule sample: 29% of rules carry no ATT&CK mapping, 55% cite no references, 61% document no false positives. That's a publishable finding about the state of open detection content, it's defensible because your methodology page shows the counting, and it's the sort of number that gets cited in conference talks. It's also a much better lead than the catalog.

► SMALLER NOTES

SECOND REVIEW OF DETECTIONEXPLORER.IO · 31 AUGUST 2026 · FINDINGS R01-R25 · ALL
MEASUREMENTS TAKEN LIVE AGAINST PRODUCTION